

TABLE OF CONTENTS

TABLE OF CONTENTS	1
1. PROJECT OVERVIEW	7
2. CURRENTLY IMPLEMENTED FEATURES (AS-IS SYSTEM).....	8
2.1 Mobile Application (Currently Implemented)	8
2.1.1 Authentication	8
2.1.2 Folder-Based Document Interface.....	8
2.1.3 Document Viewing	8
2.1.4 File Uploading	9
2.1.5 Individual Folder Creation (Training Qualifications)	9
2.1.6 Native Sharing	9
2.1.7 Push Notifications	9
2.1.8 Backend Communication	9
2.2 Admin Web Panel (Currently Implemented).....	10
2.2.1 Authentication & Role Control	10
2.2.2 Users Module (Admin).....	10
View User (Admin) – Admin can manage:	10
2.2.3 Categories Module	11
2.2.4 Companies Module	11
2.2.5 Company User Interface	11
2.2.6 Standard Documents Module	12
2.2.7 Archive Module	12
2.2.8 File Storage Management.....	12
2.2.9 Email & Notification Integration	12
3. CORE FUNCTIONAL SCOPE (2026 ROADMAP).....	13
3.1 Foundation Layer (Mandatory Architectural Upgrades).....	13
3.1.1 Database Migration (SQLite → MariaDB).....	13
3.1.2 API Versioning & Backward Compatibility	14
3.1.3 Background Job & Queue Architecture	14

3.1.4 JPG-to-PDF Conversion Engine.....	14
3.1.5 File Storage & Backup Strategy	15
3.1.6 Virtual Folder System (Resolution of "Ghost Folder" Issue).....	15
3.1.7 Logging, Monitoring & Error Tracking	15
3.1.8 Transaction & Data Integrity Controls.....	16
3.1.9 Web UI Realignment & Dashboard Separation	16
4. MODULE 1 – ENHANCED DOCUMENTS & E-SIGNATURES	16
4.1 Draw + Password Signature System	17
4.1.1 Signature Capture (Mobile)	17
4.1.2 Supervisor Verification (Counter-Sign)	17
4.1.3 Hashing & Integrity	17
4.1.4 Embedded Metadata.....	17
4.1.5 Document Locking	18
4.2 signature_logs Table (Audit Architecture)	18
4.2.1 Relational Mapping	18
4.2.2 Stored Immutable Metadata	18
4.2.3 Audit & Legal Retrieval.....	19
4.3 Sub-Contractor CRM	19
4.3.1 Sub-Contractor Entity Creation.....	19
4.3.2 Auto-Generated Compliance Structure.....	19
4.3.3 Dynamic Creation.....	20
4.3.4 Document Association.....	20
5. MODULE 2 – TRAINING & COMPLIANCE MONITORING	21
5.1 Traffic Light Expiry System	21
5.2 Gap Analysis Reporting Engine	22
5.3 Automated Reminder Scheduler	22
5.4 Zip Export System	23
6. MODULE 3 – ASSET MANAGEMENT	23
6.1 Asset CRUD System	24
6.2 Rapid Entry (Photo-to-Title)	24
6.3 Asset Dashboard Integration	25
7. MODULE 4 – PROJECT MANAGEMENT	25
7.1 Year-Based Hierarchy	25

7.2 Auto-Seed 13 Standard Folders	26
7.3 Interrogation Search Engine	27
7.4 Per-Page Electronic Sign-Off.....	27
8. MISSING FUNCTIONAL REQUIREMENTS.....	27
8.1 Tenant & User Model.....	27
8.1.1 Required	28
8.1.2 Recommended.....	28
8.2 Document Lifecycle	28
8.2.1 Required	28
8.2.2 Recommended.....	28
8.3 Workflow Rules.....	29
8.3.1 Required	29
8.3.2 Recommended.....	29
8.4 Mobile Synchronization.....	29
8.4.1 Required (if offline capability is implemented)	29
8.4.2 Recommended.....	29
8.5 Notifications.....	29
8.5.1 Required	29
8.5.2 Recommended.....	30
9. DATA MODEL (MANDATORY).....	30
9.1 Core Entities – Required.....	30
9.2 Core Relationships – Required	31
10. API SPECIFICATION	31
10.1 Authentication APIs (Required).....	31
10.2 Company & User Management APIs (Required).....	32
10.3 Project & Folder APIs (Required).....	32
10.4 Asset APIs (Required)	32
10.5 Document & Upload APIs (Required)	33
10.6 Signature APIs (Required)	33
10.7 Inspection & Timesheet APIs (Required)	33
10.8 Reporting & Search APIs (Required)	33
10.9 General API Requirements	34
11. SECURITY REQUIREMENTS	34

11.1 Authentication & Access Control (Required)	34
11.2 Encryption & Transport Security (Required).....	34
11.3 Data Protection & Isolation (Required).....	35
11.4 Signature Integrity & Audit Trail (Required).....	35
11.5 Logging & Monitoring (Required)	35
11.6 Data Retention & Compliance (Required)	36
11.7 Infrastructure Security (Required)	36
12. DEVOPS & DEPLOYMENT REQUIREMENTS	36
12.1 Environment Structure (Required)	36
12.2 CI/CD Pipeline (Required)	37
12.3 Database Management (Required).....	37
12.4 File Storage Strategy (Required)	38
12.5 Monitoring & Observability (Required)	38
12.6 Availability & Reliability (Required)	38
12.7 Release Management (Required).....	39
13. EDGE CASES & FAILURE HANDLING REQUIREMENTS.....	39
13.1 File & Upload Failures (Required).....	39
13.2 JPG-to-PDF Conversion Failures (Required).....	40
13.3 Signature & Locking Edge Cases (Required).....	40
13.4 Cross-Tenant Data Access Protection (Required)	41
13.5 Inspection & Timesheet Edge Cases (Required)	41
13.6 Archive & Deletion Edge Cases (Required)	41
13.7 System Capacity & Performance Boundaries (Required).....	42
14. ACCEPTANCE CRITERIA & SUCCESS METRICS	42
14.1 Performance Criteria (Required).....	42
14.2 Data Integrity Criteria (Required)	43
14.3 Security Criteria (Required)	43
14.4 Functional Completion Criteria (Required)	43
14.5 Reliability & Availability Criteria (Required)	44
14.6 User Experience Criteria (Required)	44
15. DELIVERABLES & DOCUMENTATION REQUIREMENTS	44
15.1 Technical Requirements (Required)	45
15.1.1 System Architecture Overview	45

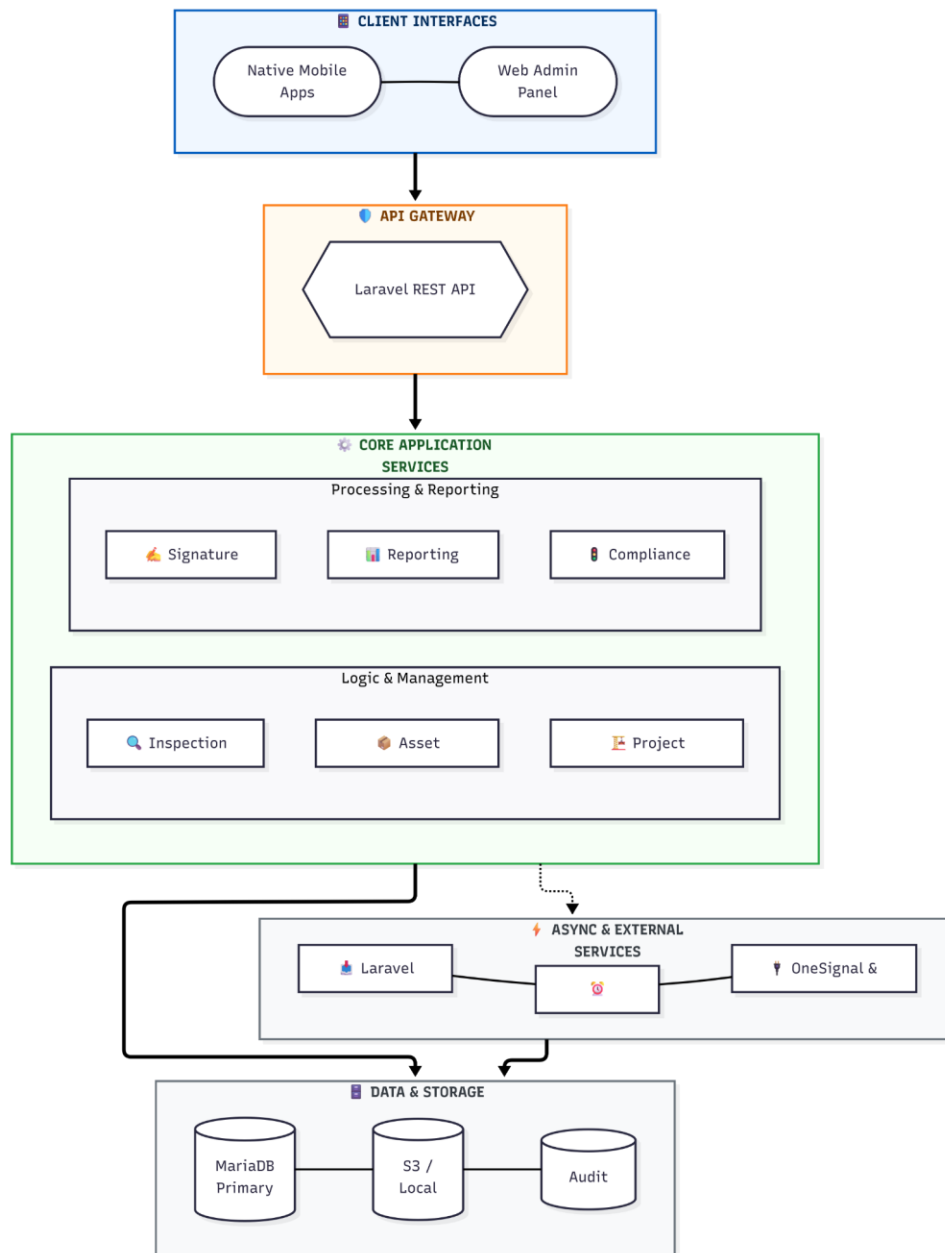
15.1.2 Entity Relationship Diagram (ERD)	45
15.1.3 API Documentation	45
15.1.4 Migration Plan	45
15.1.5 Folder & Document Structure Specification	45
15.2 Security & Compliance Documentation (Required)	45
15.2.1 Security Checklist.....	45
15.2.2 Audit Trail Specification.....	46
15.2.3 Data Retention & Archival Policy	46
15.3 Operational Documentation (Required)	46
15.3.1 Deployment Guide	46
15.3.2 Backup & Restore Procedure	47
15.3.3 Monitoring & Logging Guide	47
15.4 Testing & Validation Artifacts (Required)	47
15.4.1 Test Cases & Acceptance Tests	47
15.4.2 Performance Test Results.....	47
15.5 Release Deliverables (Required)	48
16. IMPLEMENTATION STRATEGY OPTIONS	48
16.1 Stack	49
Backend & API.....	49
Database	49
File Processing	49
Storage	49
Authentication & Security	50
Notifications	50
DevOps & Infrastructure.....	50
17. REACT NATIVE ARCHITECTURE	50
17.1 Overview	51
17.2 Team Structure.....	51
17.3 Stack	51
Mobile Framework	51
17.4 Architecture Model.....	51
17.5 Estimated Timeline	52
17.6 Estimated Investment	Error! Bookmark not defined.

17.7 Execution Model – Parallel Work Schedule	52
Months 1–1.5 (Accelerated Foundation)	52
Months 2–3 (Feature Build Phase).....	53
Month 4 (Advanced Integration Phase)	53
Month 5 (Production Phase).....	54
17.8 Advantages	54
17.9 Considerations.....	55
19. COMMERCIAL STRUCTURE	55
19.1 – React Native	55
Milestones & Payments.....	55
20. NEXT STEPS.....	55
20.1 Implementation Governance	55
20.2 Risk Management Commitment.....	56
20.3 Commercial Terms Summary	56
20.4 Closing Statement	57

1. PROJECT OVERVIEW

This proposal defines the architectural expansion, compliance enhancements, mobile evolution strategy, and operational hardening of **Safety Tracker Pro** under the 2026 Roadmap.

The objective is to transform the platform from a document repository into a legally defensible, scalable compliance management system with structured audit controls and modernized mobile capabilities.



2. CURRENTLY IMPLEMENTED FEATURES (AS-IS SYSTEM)

This section outlines what is presently implemented in the system (pre-Roadmap 2026). These features reflect the live, working functionality.

2.1 Mobile Application (Currently Implemented)

2.1.1 Authentication

- Email + password login
- Password reset via email link
- Secure credential storage (Android Account Manager / iOS UserDefaults session storage)
- Mobile login is fully separated from web login

2.1.2 Folder-Based Document Interface

Upon login, users see 6 predefined folders:

- Safety Statements
- Company Documents (with predefined subfolders)
- Risk Assessment (with predefined subfolders)
- Method Statements
- Training Registers
- Training Qualifications (with individual subfolder creation)

2.1.3 Document Viewing

- Users can open and view stored PDF documents
- Read-only access for assigned documents

2.1.4 File Uploading

- Upload via file picker (gallery/files)
- Capture via device camera
- Required document naming before upload
- Files stored on Node backend via API

2.1.5 Individual Folder Creation (Training Qualifications)

- App users can create named “Individual” folders
- Documents can be uploaded inside those folders
- Names stored in database

2.1.6 Native Sharing

- Select documents or folders
- Trigger device’s native email client
- Auto-attach selected PDFs
- Auto-generate subject line

2.1.7 Push Notifications

- Integrated with OneSignal
- Receives notifications triggered from backend

2.1.8 Backend Communication

- REST API communication with Nest backend
- Environment configuration (dev / staging / production)

2.2 Admin Web Panel (Currently Implemented)

2.2.1 Authentication & Role Control

- Admin login (web only)
- Company User login (web only)
- Strict role-based access control
- Admin impersonation of Company Users

2.2.2 Users Module (Admin)

- Create App Users
- Edit user details (Name, User ID, Email)
- Archive users
- Restore archived users
- Issue welcome email to client
- Filter users by Name, User ID, Email

View User (Admin) – Admin can manage:

Documents (6 predefined sections)

- View
- Replace (overwrite upload)
- Delete

- Filter by name

Individuals

- Add / Edit / Delete

Reminders

- Add / Edit / Delete
- Date tracking

2.2.3 Categories Module

- Add category
- Assign category to section
- Assign to specific user or all users
- Edit categories

2.2.4 Companies Module

- Create Company User
- Edit Company details
- Delete Company
- Impersonate Company User

2.2.5 Company User Interface

Company users can:

- Manage their own users
- Manage company documents

- Manage categories
- View uploaded documents
- Archive / restore users

2.2.6 Standard Documents Module

- Upload template documents
- View documents
- Edit / replace documents
- Delete documents

2.2.7 Archive Module

- View archived users
- Restore user
- Permanently delete user

2.2.8 File Storage Management

- S3 Storage
- PDFs stored on server
- File references maintained in database

2.2.9 Email & Notification Integration

- Third Party Mail for:
 - Welcome emails
 - Password resets

- Reminder notifications
- OneSignal for push notifications

3. CORE FUNCTIONAL SCOPE (2026 ROADMAP)

This section expands in detail what is proposed under the 2026 Roadmap. These are new features and architectural changes that extend the currently implemented system.

3.1 Foundation Layer (Mandatory Architectural Upgrades)

The following upgrades form the structural backbone of the 2026 Roadmap. These are system-level enhancements required to support scalability, legal compliance, performance, and long-term maintainability.

3.1.1 Database Migration (SQLite → MariaDB)

- Replace file-based SQLite engine with MariaDB/MySQL to support multi-user concurrency.
- Enable row-level locking to prevent "database locked" errors during simultaneous submissions.
- Design optimized indexing strategy for high-frequency tables:
 - signature_logs
 - inspection_forms
 - documents
 - assets
- Implement controlled migration scripts with rollback capability.
- Perform data validation and integrity checks post-migration.

- Deploy production-grade managed database hosting (e.g., dedicated server or cloud instance).

3.1.2 API Versioning & Backward Compatibility

- Introduce versioned API structure (e.g., /api/v1/).
- Ensure existing mobile applications remain functional during backend upgrades.
- Define a deprecation strategy for future API changes.
- Maintain response consistency across Android and iOS clients.

3.1.3 Background Job & Queue Architecture

- Implement Node queue workers for non-blocking operations.
- Offload heavy tasks such as:
 - JPG-to-PDF conversion
 - Zip generation
 - Reminder scheduling
 - Notification dispatch
- Configure retry policies and failure logging.
- Utilize Redis or database-backed queue system for stability.

3.1.4 JPG-to-PDF Conversion Engine

- Build server-side image processing pipeline.
- Accept .jpg / .png uploads from mobile clients.
- Compress and normalize image dimensions.
- Render images onto standardized A4 PDF canvas.

- Store finalized PDF using Node Storage façade.
- Ensure consistent formatting for audits and zip exports.

3.1.5 File Storage & Backup Strategy

- Define storage backend (local disk vs object storage such as S3-compatible service).
- Implement automated backup routines for documents and database.
- Define retention and archival storage policies.
- Plan storage scalability for high-volume photo uploads and inspections.

3.1.6 Virtual Folder System (Resolution of "Ghost Folder" Issue)

- Introduce database-backed folders table as first-class entity.
- Replace metadata-only folder labels.
- Support:
 - Folder rename
 - Folder archive / hide
 - Empty folder visibility
 - Folder-level permissions
- Synchronize folder hierarchy consistently between mobile and web.

3.1.7 Logging, Monitoring & Error Tracking

- Implement centralized application logging.
- Log failed queue jobs and PDF conversion errors.
- Track signature and inspection failures.

- Prepare monitoring hooks for server health and background services.

3.1.8 Transaction & Data Integrity Controls

- Wrap critical operations (signatures, inspections, timesheets) in database transactions.
- Enforce foreign key constraints and relational consistency.
- Prevent partial writes during multi-step operations.
- Ensure atomic state changes for document locking and approval workflows.

3.1.9 Web UI Realignment & Dashboard Separation

- Redesign admin dashboard for expanded roadmap modules.
- Add navigation for:
 - Plant & Equipment
 - Projects
 - Timesheets
 - Search / Interrogation Engine
- Introduce distinct dashboard layers:
 - Super Admin Dashboard (system-wide oversight)
 - Company Admin Dashboard (client-specific compliance view)
- Align UI structure with new module hierarchy and reporting requirements.

4. MODULE 1 – ENHANCED DOCUMENTS & E-SIGNATURES

This module transforms the system from a document storage platform into a legally defensible compliance system. It introduces structured digital signatures, immutable audit logging, and

contractor-level compliance management. The document should not be made immutable until the final signature (for multi-signature documents only) is captured.

4.1 Draw + Password Signature System

A secure, dual-verification electronic signature workflow will be implemented to ensure legal non-repudiation and audit integrity.

4.1.1 Signature Capture (Mobile)

- Capture handwritten signature via touchscreen canvas input.
- Support multiple signatures on a single document (e.g., Toolbox Talks, Inductions).
- Store signature as embedded graphic within final PDF.

4.1.2 Supervisor Verification (Counter-Sign)

- Require logged-in supervisor or account holder to re-enter their password to finalize signing.
- Password re-entry acts as identity confirmation and witness validation.
- Prevent document finalization without successful credential verification.

4.1.3 Hashing & Integrity

- Generate SHA-256 cryptographic hash of the finalized document.
- Store hash value in database to detect future tampering.
- Ensure that any modification invalidates the original signature record.

4.1.4 Embedded Metadata

Each signed document will embed:

- Timestamp (UTC standard)
- Device ID (where available)
- IP Address at time of signing
- Signatory User ID

4.1.5 Document Locking

- Once signed, document becomes immutable.
- Editing disabled unless explicitly versioned.
- Deletion restricted based on role permissions.
- Any modification requires re-signing process.

4.2 signature_logs Table (Audit Architecture)

A dedicated signature_logs table will act as a permanent audit ledger for all signature activity.

4.2.1 Relational Mapping

Foreign keys:

- user_id (signatory)
- document_id
- company_id
- Optional linkage to project_id or inspection_id (future extensibility).

4.2.2 Stored Immutable Metadata

- SHA-256 hash of finalized document
- Timestamp of signature

- IP address
- Device identifier (if available)
- Signature type (single / multi-party)
- Verification status

4.2.3 Audit & Legal Retrieval

- Enable fast querying for compliance audits.
- Support interrogation by:
 - Date range
 - Signatory
 - Company
 - Document type
- Ensure logs are append-only (no update/delete permissions).
- Designed to support insurance claims and legal dispute validation.

4.3 Sub-Contractor CRM

Introduce structured compliance management for subcontractors operating under a company.

4.3.1 Sub-Contractor Entity Creation

- Create dedicated contractor records linked to parent company.
- Store contact information and compliance status fields.

4.3.2 Auto-Generated Compliance Structure

Upon creation, automatically seed standardized folders such as:

- Insurance
- GA1 / GA2 Certificates
- Method Statements
- Risk Assessments
- Training Records

The interrogation engine can support filters like:

- Date range
- Document type
- Inspection type
- Project ID / Project Name

4.3.3 Dynamic Creation

- Allow Company Admins to create new subcontractors via “+” action.
- Support editing, archiving, and status tracking (Active / Inactive).

4.3.4 Document Association

- Link uploaded documents directly to subcontractor record.
- Enable expiry tracking and compliance reporting at contractor level.
- Include subcontractors in Traffic Light compliance dashboards (future module integration).

5. MODULE 2 – TRAINING & COMPLIANCE MONITORING

This module introduces automated compliance tracking, workforce certification visibility, and structured reporting tools to reduce manual monitoring and administrative oversight.

5.1 Traffic Light Expiry System

Implement a visual compliance status indicator for all certifications and time-sensitive documents.

- Calculate remaining days until expiry using Carbon date comparisons.

Display status as:

- Green → More than 30 days remaining
- Amber → 30 days or less remaining
- Red → Expired
- Update status dynamically based on current date.

Reflect status across:

- User profile views
- Company-level dashboards
- Asset and training listings (where applicable)

Traffic light thresholds configurable **per company**.

Example configuration table:

Company Settings:

- Green threshold: $> X$ days
- Amber threshold: $\leq X$ days
- Red threshold: expired

Example:

Company A
Amber = 30 days

Company B
Amber = 60 days

Implementation is straightforward.

5.2 Gap Analysis Reporting Engine

Provide administrators with structured reporting to identify workforce compliance gaps.

- Allow selection of specific certification type (e.g., Safe Pass, Manual Handling).
- Query active workforce records within selected company.

Categorize users into:

- Compliant (Valid certificate on file)
- Expired (Certificate exists but expired)
- Missing (No certificate recorded)
- Display results in structured table format.
- Support export capability (e.g., CSV or printable report).

5.3 Automated Reminder Scheduler

Automate certification renewal notifications using Node Scheduler.

- Run scheduled daily scan of expiry dates.

Trigger alerts at:

- 3 months before expiry
- 1 month before expiry
- 1 week before expiry

Send notifications via:

- Email
- Push notification (OneSignal)
- Ensure reminders are not duplicated once renewal is completed.

5.4 Zip Export System

Enable flexible document bundling for audits and compliance sharing.

- Provide multi-select interface across folders.
- Allow selection of individual files or entire folders.
- Generate dynamic zip archive server-side.
- Preserve folder hierarchy within the zip.
- Stream secure download link to user upon generation.

6. MODULE 3 – ASSET MANAGEMENT

This module introduces structured tracking of company plant, equipment, and calibrated tools to ensure operational compliance and visibility of expiry-based risks.

6.1 Asset CRUD System

Implement a structured Asset Management module supporting full Create, View, Edit, and Archive functionality.

Create predefined asset categories:

- Plant
- Lifting Equipment
- Working at Height
- Calibration Tools

Each asset record must store standardized metadata:

- Serial number
- Expiry date
- Description

Assets should be linked to the owning company and support document attachments (e.g., GA certificates, inspection reports, calibration certificates). Expiry dates will serve as the basis for compliance monitoring and dashboard alerts.

The system uses **soft delete / archive logic**:

- Records are never permanently deleted
- They are flagged as deleted

This is standard SaaS practice.

6.2 Rapid Entry (Photo-to-Title)

Provide a mobile-first rapid asset registration workflow:

- Capture asset certificate or compliance sticker using the mobile device camera
- Automatically convert the captured image into a standardized PDF using the JPG-to-PDF engine
- Associate the generated PDF with the selected asset record
- Allow creation of a new asset record directly from mobile if it does not already exist

This ensures fast on-site asset induction with minimal manual data entry.

6.3 Asset Dashboard Integration

Integrate asset expiry data into the Company Admin dashboard.

Display clear indicators for:

- Expired assets
- Assets approaching expiry

Provide direct navigation from dashboard alerts to the corresponding asset record to allow quick review and corrective action.

7. MODULE 4 – PROJECT MANAGEMENT

This module introduces structured project organization, standardized compliance folders, and advanced document retrieval as defined in the 2026 Roadmap.

7.1 Year-Based Hierarchy

Implement a temporal organization system beginning with years (e.g., 2025, 2026, 2027).

- Projects organized under year folders (2025, 2026, etc.)
- Document timestamps stored in **UTC**
- Expiry and inspection dates stored as **ISO date fields**

This ensures consistent project organization and simplifies long-term record management.

7.2 Auto-Seed 13 Standard Folders

Upon creation of a new project, automatically generate the required 13 standardized compliance sub-folders:

- Preliminary Plan
- AF1/AF2
- Appointments
- Plans
- Drawings
- Method Statements
- Inductions
- Toolbox Talks
- Site Audits
- SSWP
- Permits
- Accident Reports
- MSDS

This guarantees that every project follows a consistent compliance structure without requiring manual folder setup.

7.3 Interrogation Search Engine

Implement an advanced documentation retrieval system for project records.

Support filtering by:

- Date range
- Signatory
- Document type
- Inspection type

This functionality allows administrators to quickly locate specific documents or sign-off records during audits or investigations.

7.4 Per-Page Electronic Sign-Off

Enable electronic signing capabilities within relevant project documentation.

- Capture signatures on individual document sections where required
- Lock document after signing
- Generate and store verification hash for finalized documents
- Partial signatures allowed
- Document remains editable until finalization

8. MISSING FUNCTIONAL REQUIREMENTS

This section distinguishes between requirements that are mandatory for system stability and legal integrity and those that are recommended for scalability and operational maturity.

8.1 Tenant & User Model

8.1.1 Required

- Company Isolation Model – Strict tenant-level data separation to prevent cross-company data access.
- Role Matrix – Clearly defined permissions for:
 - Super Admin
 - Company Admin
 - App User
 - Sub-contractor
 - Read-only auditor
- Password Reset – Secure, token-based reset mechanism.

8.1.2 Recommended

- User Invitation Flow – Controlled onboarding process.
- MFA Option – Optional multi-factor authentication for enhanced security.

8.2 Document Lifecycle

8.2.1 Required

- Lock After Signature – Signed documents must become immutable.
- Re-Sign After Edit – Any modification invalidates prior signature.
- Soft Delete + Archive – Prevent permanent loss of compliance records.

8.2.2 Recommended

- Versioning of Documents – Maintain traceable revision history.

- Retention Policy – Define formal data retention duration.

8.3 Workflow Rules

8.3.1 Required

- Approval Chains – Clearly defined approval path where applicable.
- Rejection Comments – Mandatory reason when rejecting submissions.

8.3.2 Recommended

- Reassignment – Allow delegation of approvals.
- Escalation Rules – Automated handling of delayed approvals.

8.4 Mobile Synchronization

8.4.1 Required (if offline capability is implemented)

- Offline Queue – Local storage of submissions during network loss.
- Conflict Resolution – Defined behavior for simultaneous edits.

8.4.2 Recommended

- Background Upload – Non-blocking upload handling.
- Resume Broken Upload – Continue interrupted uploads where possible.

8.5 Notifications

8.5.1 Required

- Email Templates – Structured templates for system alerts.
- Push Templates – Standardized push notification formatting.

8.5.2 Recommended

- Digest Mode – Aggregated summary notifications to reduce alert fatigue.

9. DATA MODEL (MANDATORY)

This section defines the structural entities required to support the roadmap functionality.

9.1 Core Entities – Required

The following entities are mandatory:

- companies
- users
- roles
- projects
- folders
- documents
- signatures
- assets
- certifications
- timesheets
- notifications

- audit_logs

Each must include proper indexing and foreign key enforcement.

9.2 Core Relationships – Required

The following relationships are mandatory:

- Company → Users (1:N)
- Company → Projects (1:N)
- Project → Folders (1:N)
- Folder → Documents (1:N)
- Document → Signatures (1:N)

All relationships must enforce referential integrity to prevent orphaned records and ensure data consistency.

10. API SPECIFICATION

This section defines the minimum required API surface necessary to support web, mobile, and administrative operations. All endpoints must enforce authentication, authorization (RBAC), and company-level isolation.

10.1 Authentication APIs (Required)

- Login – Authenticate user and return secure session/token.
- Register / Invitation Activation – Complete account setup (if invitation flow enabled).
- Password Reset Request – Generate secure reset token.

- Password Reset Confirm – Validate token and update password.
- Logout – Invalidate session/token.
- Token Expiry, Refresh Token and Timeout will be enforced

All authentication endpoints must enforce rate limiting and secure token handling.

10.2 Company & User Management APIs (Required)

- Company CRUD (Create, View, Update, Archive where applicable).
- User CRUD (Create, Update, Archive, Role assignment).
- Role assignment and retrieval.
- User listing scoped by company.

All user and company endpoints must enforce strict tenant isolation.

10.3 Project & Folder APIs (Required)

- Project CRUD under company scope.
- Auto-seed folder generation on project creation.
- Folder listing and hierarchy retrieval.
- Folder-level document retrieval.

10.4 Asset APIs (Required)

- Asset CRUD operations.
- Asset listing by company.
- Asset expiry retrieval (for dashboard integration).

- Document attachment to asset.

10.5 Document & Upload APIs (Required)

- Document upload (with validation).
- Document retrieval (scoped access).
- Document delete/archive (based on role).
- JPG-to-PDF & PNG-to-PDF conversion endpoint (background processed).
- Zip generation endpoint (multi-select support).

10.6 Signature APIs (Required)

- Submit signature (Draw + Password verification).
- Finalize and lock document.
- Retrieve signature logs (filtered by date, user, document type).

10.7 Inspection & Timesheet APIs (Required)

- Inspection form submission.
- Inspection retrieval and filtering.
- Timesheet submission.
- Timesheet approval/rejection endpoint.
- Employer review queue retrieval.

10.8 Reporting & Search APIs (Required)

- Interrogation search endpoint (filter by date range, signatory, document type, inspection type).
- Gap analysis report endpoint.
- Traffic light status summary endpoint.

10.9 General API Requirements

All APIs must:

- Require authenticated access.
- Enforce role-based access control.
- Enforce company-level data isolation.
- Support pagination for large datasets.
- Return standardized JSON responses.

11. SECURITY REQUIREMENTS

This section defines the mandatory security controls required to ensure data protection, regulatory compliance, and tenant isolation across the system.

11.1 Authentication & Access Control (Required)

- Enforce secure authentication for all web and mobile users.
- Implement Role-Based Access Control (RBAC) middleware across all endpoints.
- Ensure strict company-level (tenant) data isolation.
- Prevent privilege escalation between roles (e.g., App User cannot access admin APIs).
- Automatically invalidate sessions upon logout or password reset.

11.2 Encryption & Transport Security (Required)

- Enforce HTTPS (TLS) for all API communication.
- Encrypt sensitive data in transit.
- Store passwords using secure hashing (bcrypt or stronger).
- Protect authentication tokens using secure storage mechanisms on mobile devices.

11.3 Data Protection & Isolation (Required)

- Ensure zero cross-company data exposure.
- Enforce query scoping at database level (company_id filtering).
- Protect direct file access through controlled Node Storage access rules.
- Prevent direct URL-based access to documents without authorization checks.

11.4 Signature Integrity & Audit Trail (Required)

- Store immutable signature metadata.
- Generate SHA-256 verification hash for signed records.
- Prevent editing of signed and locked documents.
- Maintain audit logs for signature events and critical actions.

11.5 Logging & Monitoring (Required)

- Log authentication attempts (successful and failed).
- Log critical system actions (document deletion, signature finalization, approval/rejection events).
- Maintain timestamped audit records for dispute resolution.

- Ensure logs are tamper-resistant.

11.6 Data Retention & Compliance (Required)

- Implement configurable retention policy for archived records.
- Allow soft delete before permanent deletion (where applicable).
- Ensure compliance with GDPR principles (data minimization, access control, deletion upon request where applicable).

11.7 Infrastructure Security (Required)

- Production environment separation (dev / staging / production).
- Secure database configuration (restricted external access).
- Regular backups with tested restore procedure.
- Controlled access to server and database environments.

12. DEVOPS & DEPLOYMENT REQUIREMENTS

This section defines the operational and infrastructure requirements necessary to support stability, scalability, and maintainability of the system.

12.1 Environment Structure (Required)

Maintain clearly separated environments:

- Development (dev)
- Staging (pre-production testing)
- Production

Each environment must:

- Use separate database instances.
- Use separate storage locations.
- Have isolated configuration variables (API keys, DB credentials, OneSignal keys, etc.).
- No production data should ever be used in development environments.

12.2 CI/CD Pipeline (Required)

Implement a structured deployment pipeline for:

- Web application (Nest backend).
- Android application.
- iOS application.

Requirements:

- Version control via Git.
- Automated build process for staging and production.
- Controlled release process for App Store and Google Play submissions.
- Environment-based configuration management.

12.3 Database Management (Required)

- Migration scripts for schema updates.
- Controlled rollout of database changes.
- Automated daily backups of production database.
- Backup retention policy.

- Tested restore procedure to validate backup integrity.

12.4 File Storage Strategy (Required)

- Secure storage for uploaded PDFs and generated documents.
- Structured directory organization by company/project.
- Access-controlled retrieval via backend only (no public exposure).
- Monitoring of storage growth and capacity planning.

12.5 Monitoring & Observability (Required)

- Application error logging (backend + mobile).
- Centralized logging for production environment.

Monitoring of:

- API response times
- Database performance
- Storage usage
- Failed login attempts
- Alerting mechanism for critical system failures.

12.6 Availability & Reliability (Required)

- Target 99.9% uptime for production system.
- Proper database configuration to handle concurrent writes (MariaDB).

Graceful error handling for:

- Failed uploads
- Failed PDF conversion
- Network interruptions

12.7 Release Management (Required)

- Version tagging for all production releases.
- Change log documentation.
- Rollback procedure defined for failed deployments.

13. EDGE CASES & FAILURE HANDLING REQUIREMENTS

This section defines how the system must behave under abnormal, failure, or boundary conditions to ensure reliability and data integrity.

13.1 File & Upload Failures (Required)

The system must gracefully handle:

- Failed file uploads (network interruption).
- Partial uploads (connection drop mid-transfer).
- Duplicate uploads of the same file.
- Large file uploads exceeding defined limits.
- Unsupported file formats.

Requirements:

- Return clear error responses to the user.
- Prevent corrupted or partial files from being stored.
- Enforce file size and type validation server-side.
- Ensure resumable or retry logic where applicable (especially for mobile).

13.2 JPG-to-PDF Conversion Failures (Required)

If PDF generation fails:

- Do not store incomplete output.
- Return structured error response.
- Log conversion error in system logs.
- Allow retry of conversion process.
- The original uploaded image should not be lost unless conversion succeeds.

13.3 Signature & Locking Edge Cases (Required)

Handle scenarios such as:

- Session expiration during signing process.
- Supervisor password entered incorrectly.
- Attempt to edit a locked/signed document.
- Attempt to delete a signed document.

Requirements:

- Prevent modification of locked records.
- Maintain signature integrity.

- Log failed signature attempts.

13.4 Cross-Tenant Data Access Protection (Required)

Prevent:

- Accessing another company's documents via URL manipulation.
- Accessing records by guessing document IDs.

All database queries must enforce company-level filtering.

13.5 Inspection & Timesheet Edge Cases (Required)

Handle:

- Submission while offline (if offline module enabled).
- Duplicate inspection submission.
- Re-submission after rejection.
- Approval conflict (two admins attempting action simultaneously).

System must:

- Prevent double approval.
- Maintain consistent approval state.
- Log state transitions.

13.6 Archive & Deletion Edge Cases (Required)

- Prevent permanent deletion of active referenced records.
- Ensure soft-deleted items do not appear in active lists.

- Maintain referential integrity across:
 - Projects
 - Documents
 - Signatures
 - Assets

13.7 System Capacity & Performance Boundaries (Required)

Define and enforce:

- Maximum upload size.
- Maximum concurrent request threshold.
- Pagination for large result sets.
- Search time targets (< 2 seconds under defined load).

14. ACCEPTANCE CRITERIA & SUCCESS METRICS

This section defines measurable conditions that must be satisfied before the system is considered production-ready under the expanded roadmap scope.

14.1 Performance Criteria (Required)

- Interrogation search must return results in under 2 seconds on a dataset of at least 100,000 documents.
- API response time under normal load must remain within acceptable thresholds (e.g., <500ms for standard CRUD requests).

- File upload and PDF conversion must complete within defined timeout limits without blocking the system.
- Dashboard pages must load within acceptable performance thresholds under realistic usage.

14.2 Data Integrity Criteria (Required)

- No cross-company data visibility under any scenario.
- Signed and locked documents must be immutable.
- Signature hashes must remain verifiable and unchanged.
- Database migration from SQLite to MariaDB must result in zero data loss.
- Referential integrity must be maintained across all entities.

14.3 Security Criteria (Required)

- All endpoints must require authentication.
- Role-based access must be enforced on every protected route.
- Signed documents cannot be edited or deleted without defined archival workflow.
- TLS must be enforced for all production API communication.
- Audit logs must capture critical actions (signatures, approvals, deletions).

14.4 Functional Completion Criteria (Required)

The following modules must be fully operational:

- Database migration completed and stable.
- JPG-to-PDF and PNG-to-PDF conversion functioning reliably.

- Virtual folder system resolving “Ghost Folder” issue.
- Asset management CRUD fully functional.
- Digital inspection forms operational.
- Timesheet submission and approval workflow operational.
- Interrogation search engine functioning across required filters.
- Traffic light compliance indicators visible in dashboards.
- Timesheets should be treated as structured data, not graphics.

14.5 Reliability & Availability Criteria (Required)

- Production environment must achieve 99.9% uptime.
- Automated backups must be scheduled and tested.
- System must handle concurrent inspection and timesheet submissions without database locking errors.
- Graceful failure handling must be verified under simulated network interruptions.

14.6 User Experience Criteria (Required)

- Mobile and web views must reflect consistent folder and document hierarchy.
- Signed documents must clearly display signature and timestamp.
- Expiry indicators (Green/Amber/Red) must update dynamically based on date.
- Zip export must preserve folder structure inside archive.

15. DELIVERABLES & DOCUMENTATION REQUIREMENTS

This section defines the required outputs that must be delivered alongside the developed system to ensure maintainability, audit readiness, and operational continuity.

15.1 Technical Requirements (Required)

The following documentation must be delivered:

15.1.1 System Architecture Overview

High-level architecture diagram showing web, mobile, database, storage, and external services.

15.1.2 Entity Relationship Diagram (ERD)

Complete database schema including all entities and relationships.

15.1.3 API Documentation

Endpoint definitions, request/response structures, authentication requirements, and example payloads.

15.1.4 Migration Plan

Detailed procedure for SQLite → MariaDB migration including:

- Data validation steps
- Rollback plan
- Downtime strategy (if required)

15.1.5 Folder & Document Structure Specification

Clear documentation of folder hierarchy and virtual folder logic.

15.2 Security & Compliance Documentation (Required)

15.2.1 Security Checklist

Confirmation of:

- TLS enforcement

- RBAC implementation
- Tenant isolation
- Signature hashing mechanism

15.2.2 Audit Trail Specification

Explanation of:

- signature_logs structure
- inspection audit logging
- approval/rejection logging

15.2.3 Data Retention & Archival Policy

Document outlining:

- Soft delete process
- Permanent deletion rules
- Retention timelines

15.3 Operational Documentation (Required)

15.3.1 Deployment Guide

Step-by-step instructions for:

- Environment setup
- Configuration variables
- Database provisioning
- Storage configuration

15.3.2 Backup & Restore Procedure

Verified process for:

- Database restoration
- File storage restoration

15.3.3 Monitoring & Logging Guide

Description of:

- Log locations
- Alert triggers
- Error escalation procedures

15.4 Testing & Validation Artifacts (Required)

15.4.1 Test Cases & Acceptance Tests

Covering:

- Signature flow
- Inspection submission
- Timesheet approval
- Traffic light compliance
- Search functionality

15.4.2 Performance Test Results

Verification of:

- Search under load

- Concurrent submissions
- File processing reliability

15.5 Release Deliverables (Required)

- Versioned production build (web + mobile).
- Updated database schema.
- Confirmed CI/CD pipeline configuration.
- Final change log summarizing implemented roadmap items.

16. IMPLEMENTATION STRATEGY OPTIONS

As part of the 2026 Roadmap execution, two viable delivery approaches are available.

Both options include:

- SQLite → MariaDB migration
- Backend refactoring & API restructuring
- Admin Panel redesign & expansion
- Digital signature system (Draw + Password + Hash)
- Asset management module
- Project management module
- Inspection & Timesheet workflows
- Gap analysis & reporting engine
- Interrogation search engine
- Zip export system

- Performance optimization & production hardening

16.1 Stack

Backend & API

- Framework: Nest.js
- Language: Typescript, Javascript
- Architecture: RESTful API with versioning (/api/v1)
- ORM: Eloquent ORM
- Queue System: Node Queues (Redis or DB-backed)
- Scheduler: Node Cron Scheduler

Database

- Primary DB: MariaDB (Production)
- Migration from: SQLite
- Indexing Strategy: Optimized indexes on signature_logs, inspections, documents, assets
- Transaction Support: Full transactional integrity

File Processing

- Image Processing: ImageMagick or GD Library
- PDF Generation: DomPDF or TCPDF
- Storage Layer: S3 or file system

Storage

- Local disk or S3-compatible object storage (final selection during infrastructure setup)

Authentication & Security

- JWT Auth (Token-based API authentication)
- bcrypt password hashing
- SHA-256 document hashing
- RBAC middleware
- HTTPS/TLS enforced

Notifications

- 3rd Party Mail
- OneSignal Push Notifications

DevOps & Infrastructure

- Linux-based server environment
- Nginx
- Git-based version control
- CI/CD pipeline
- Separate Dev / Staging / Production environments
- Automated database backups

17. REACT NATIVE ARCHITECTURE

17.1 Overview

This approach consolidates mobile development into a single React Native codebase while evolving backend and admin systems in parallel. This is Technically recommended option
This removes duplication between Android and iOS development.

17.2 Team Structure

- 2 Part - time Mobile App Developer (for Maintenance only)
- 2 Backend Developers
- 1 React Native Developer
- 1 Part-Time QA
- 1 Project Manager

17.3 Stack

Mobile Framework

- Framework: React Native (Latest Stable)
- Language: TypeScript
- Navigation: React Navigation
- Networking: Axios
- State Management: Redux Toolkit or Context API
- Local Storage: AsyncStorage + SQLite (offline module)
- Push: OneSignal React Native SDK
- Build System: EAS / Native build pipelines
- Deployment: Single codebase → Android & iOS

17.4 Architecture Model

- Shared business logic
- Shared UI components
- Single mobile codebase
- Unified release cycle

17.5 Estimated Timeline

~4.5–5 Months (18–20 Weeks)

17.7 Execution Model – Parallel Work Schedule

Months 1–1.5 (Accelerated Foundation)

Backend Developer A

- MariaDB migration
- Indexing & performance optimization
- Scheduler infrastructure

Backend Developer B

- Virtual Folder System
- Signature logic (SHA-256 + locking)
- Asset & inspection schema
- API restructuring

React Native (Begins Week 3)

- Application architecture
- Authentication flow

- Folder system UI
- Upload scaffolding
- Document viewer base

Months 2–3 (Feature Build Phase)

Backend

- Admin dashboards
- Timesheet workflow
- Gap analysis
- Interrogation search
- Zip export system
- API stabilization

React Native

- API integration
- Signature integration
- Inspection module
- Asset module
- Timesheet module
- Folder synchronization

QA performs continuous validation.

Month 4 (Advanced Integration Phase)

Private & Confidential



www.zaytrics.com

Backend

- Performance tuning
- Security validation
- Bug fixes from integration

React Native

- Offline queue
- Retry logic
- Conflict handling
- Stability tuning

Month 5 (Production Phase)

All streams:

- Load testing
- Full regression
- Store submission
- Production deployment

17.8 Advantages

- Single mobile codebase
- Faster delivery
- Lower long-term maintenance cost
- Improved scalability

17.9 Considerations

- Full mobile refactor required
- Short transition phase

19. COMMERCIAL STRUCTURE

19.1 – React Native

Duration: ~4.5–5 Months

Milestones & Payments

Phase	Description	Timeline
Project Initiation	Project initiation, architecture setup, RN base setup	Project Start
Milestone 1	MariaDB Migration, API Refactor, Virtual Folder System, JPG-to-PDF Engine	End of Month 1.5
Milestone 2	Admin Panel Expansion (Dashboards, Asset Module, Project Module, Search Engine)	End of Month 2.5
Milestone 3	React Native Core App (Auth, Folders, Signature, Assets, Inspections)	End of Month 3.5
Milestone 4	Timesheets, Offline Sync, Zip Export, Advanced Integrations	End of Month 4.5
Milestone 5	QA, Optimization, Production Release	Month 5
Total		

20. NEXT STEPS

20.1 Implementation Governance

Upon approval, the following will occur immediately:

- Final technical architecture confirmation

- Detailed sprint breakdown (bi-weekly cycles)
- Project kickoff meeting
- Environment provisioning
- Formalized development calendar

Progress reporting will include:

- Weekly status updates
- Milestone demonstrations
- Issue tracking visibility
- Pre-release validation reviews

20.2 Risk Management Commitment

The execution plan includes:

- Controlled SQLite → MariaDB migration with rollback safeguards
- Strict tenant-level data isolation
- Immutable digital signature enforcement
- Performance validation under load
- Security validation prior to production release

No production deployment will occur until all defined Acceptance Criteria are met.

20.3 Commercial Terms Summary

- Advance payment required to initiate development.
- Milestone-based billing structure.

- Clear production release gates.
- Full documentation and handover included.

20.4 Closing Statement

The 2026 Roadmap transforms the system from a document repository into a structured, legally defensible compliance platform with scalable infrastructure and modern mobile capabilities.

This proposal provides:

- Architectural stability
- Legal-grade audit controls
- Operational automation
- Scalable performance
- Clear delivery accountability

Upon confirmation of the selected option, we are prepared to begin immediately.